



Data Governance Framework

Qualité · Conformité · Confiance — à l'échelle mondiale

450 M

utilisateurs actifs

200 M

abonnés premium

180+

pays

3,4 → 4,2

maturité data /5 (M12)

Un framework fondé sur les 9 principes du Governance Principles Guide · modèle Centre of Excellence · pilote User Data en 4 mois · 3 décisions à prendre aujourd'hui

Pourquoi agir maintenant ?

3 signaux d'alarme — et un précédent

Risque réglementaire

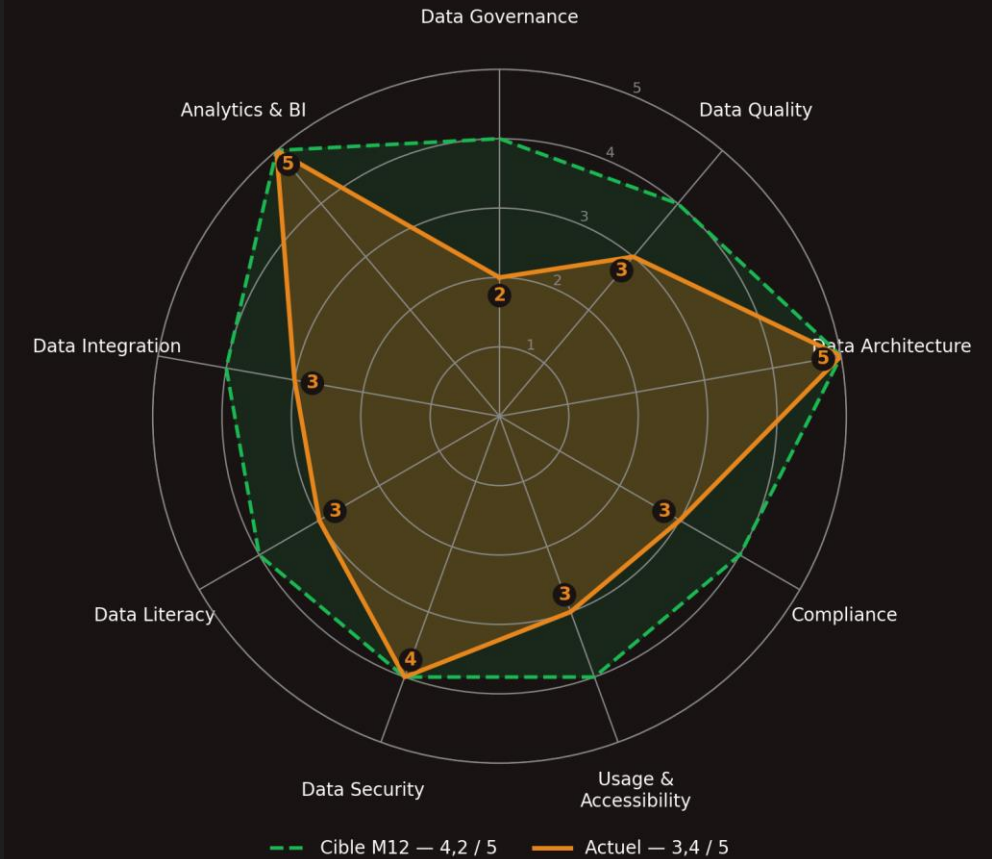
- GDPR : jusqu'à 4 % du CA mondial ≈ 530 M€ (CA 2023 : 13,25 Md€)
- Notification de violation sous 72 h · CCPA/CPRA · PDPA · LGPD · DSA
- **Précédent : IMY, juin 2023 — 58 M SEK (≈ 5 M€) pour un droit d'accès insuffisamment clair**

Silos qui freinent le business

- Marketing, Product, Engineering, Content gèrent leurs propres datasets
- « Utilisateur actif » : définition différente selon les équipes
- Parcours découverte → premium impossible à reconstituer

Confiance et éthique

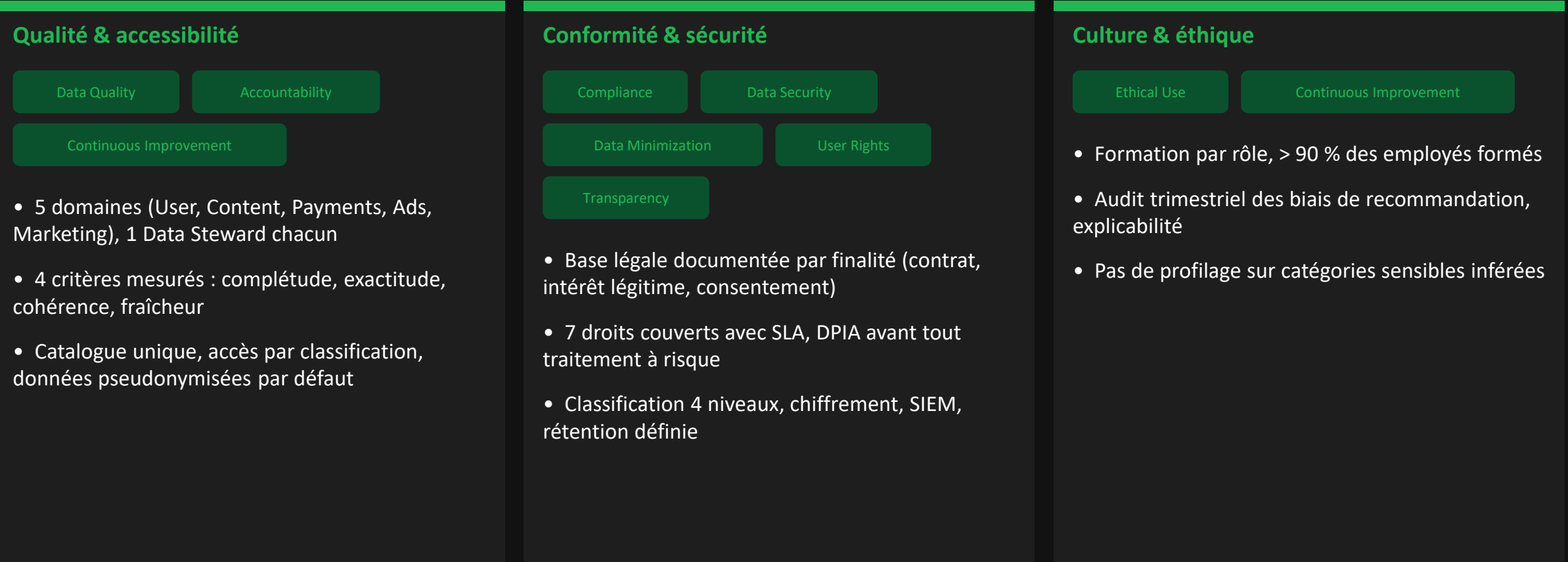
- Utilisateurs et régulateurs attendent transparence et contrôle
- Recommandations non auditées pour les biais (DSA art. 27)
- Concurrence : Apple Music, Amazon Music, YouTube Music



Maturité data : 3,4 / 5 — Governance 2 · Compliance 3 · Quality 3

Le framework : 3 piliers, 9 principes

Source : Governance Principles Guide — regroupés pour l'action



4 objectifs du business case couverts : Qualité · Conformité · Privacy · Accessibilité & intégration — Data Governance Policy v1.0 : 3 pages, 7 sections, RACI, checklist annexée

Conformité réglementaire

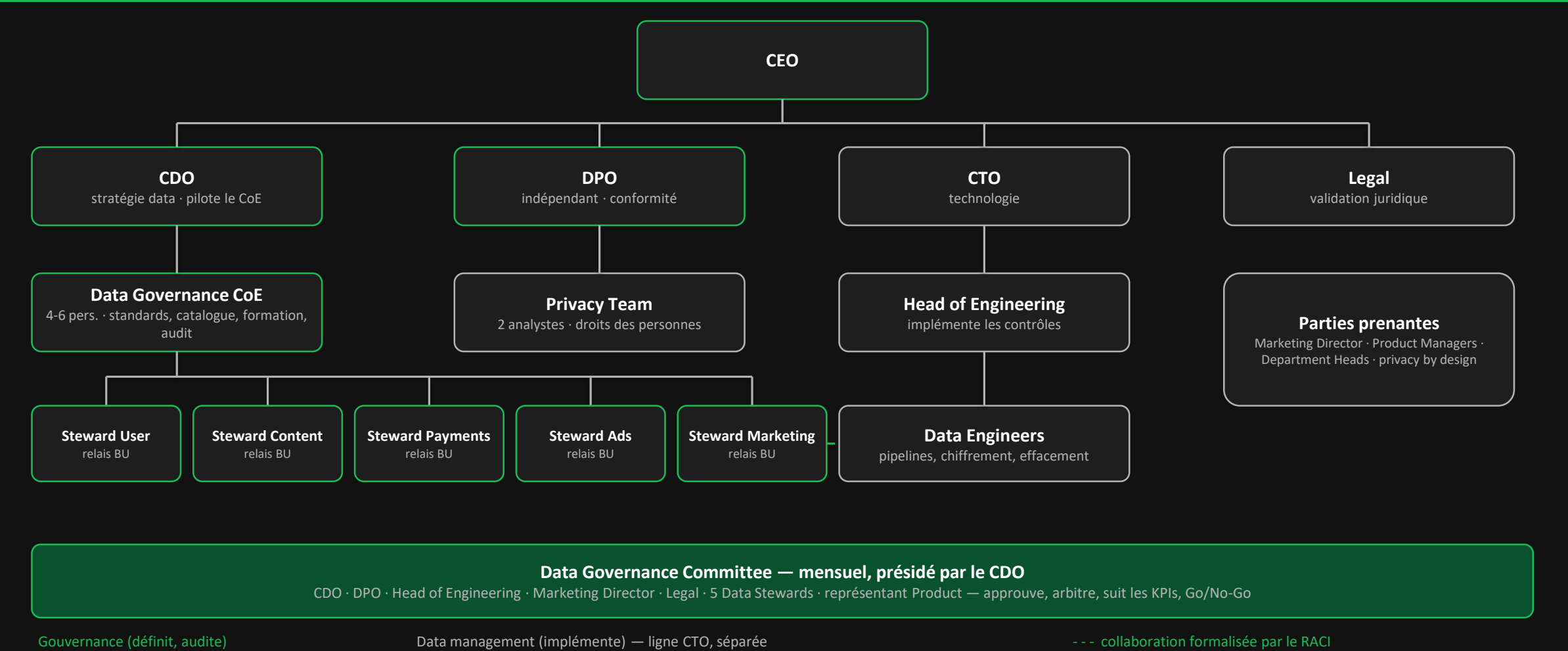
GDPR · CCPA/CPRA · PCI-DSS · réglementations locales et plateformes

GDPR — Union européenne • Base légale par finalité, registre art. 30 • 7 droits couverts, réponse < 1 mois • Notification de violation < 72 h • DPIA avant tout traitement à risque	CCPA / CPRA — Californie • « Do Not Sell or Share » + signal GPC • Accès, suppression, correction < 45 j • Non-discrimination garantie • Opt-out propagé aux partenaires	PCI-DSS — paiements • Prestataire certifié, aucun n° de carte stocké • SAQ-A annuel, MFA sur consoles • Scans trimestriels, pentest annuel • Politique de sécurité revue chaque année	Local & plateformes • PDPA Singapour · LGPD Brésil (2 % CA local) • DSA art. 27 : recommandations explicables + option non profilée • AI Act : obligations de transparence • Veille DPO + Legal, checklist trimestrielle
---	---	---	--

Outils : OneTrust (consentement, registre, DPIA, demandes) · Splunk (SIEM) · Thales/Vormetric (chiffrement) | Compliance Checklist Excel remplie : 14 exigences, statut, owner, échéance (annexe)

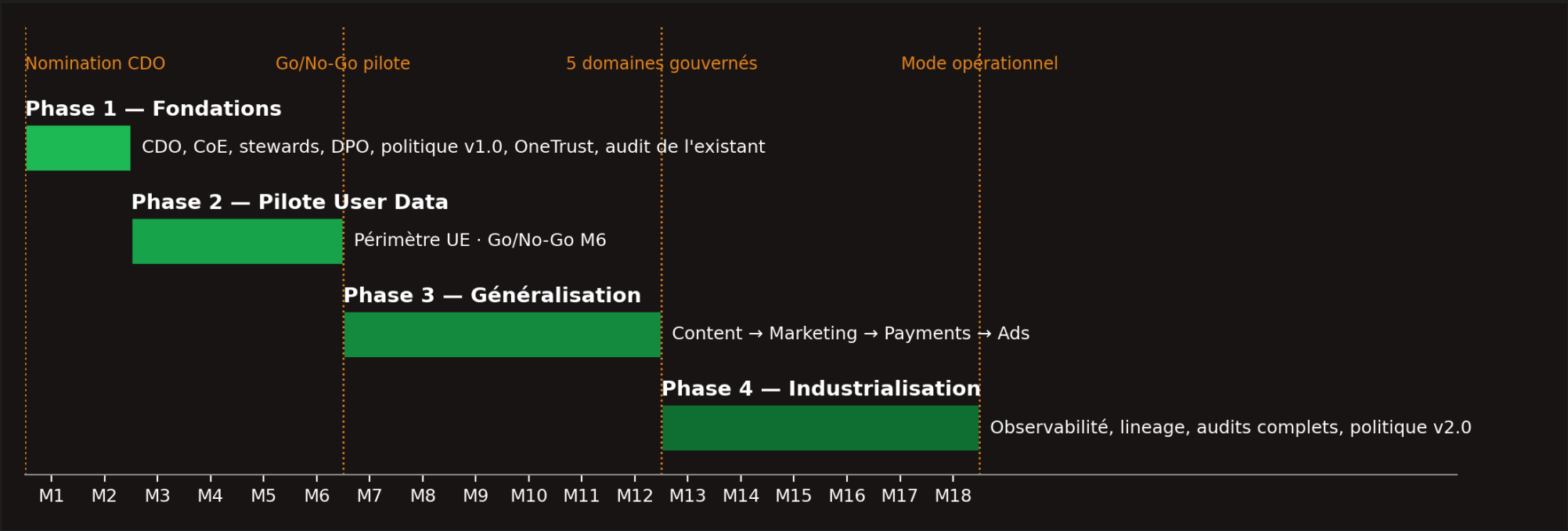
Organisation & rôles — Centre of Excellence

Source : Data Governance Roles Template · la gouvernance définit et audite, l'engineering implémente



Plan d'implémentation

4 phases · 18 mois · pilote en 4 mois — calendrier aligné sur l'Executive Q&A Guide



Catalogue	Qualité	Conformité	SIEM	Chiffrement	Lineage	Observabilité
Colibra ou extension de Lexikon	Great Expectations	OneTrust	Splunk	Thales / Vormetric	OpenLineage	Monte Carlo (ph. 4)

Pilote User Data — M3 à M6

Source : Pilot Implementation Template · périmètre borné, baselines mesurées en semaine 1

Pourquoi User Data ?

- Exposition GDPR maximale — juridiction qui a déjà sanctionné Spotify
- Données pouvant révéler des informations sensibles inférées
- Alimente Discover Weekly, Daily Mix et la rétention premium
- **Périmètre : profils et historiques d'écoute des marchés UE d'abord, extension mondiale en phase 3**
- Équipe : Lead CoE (PM), Steward User, DPO + Privacy Team, Data Engineers, VP Product
- Go/No-Go du Committee en M6

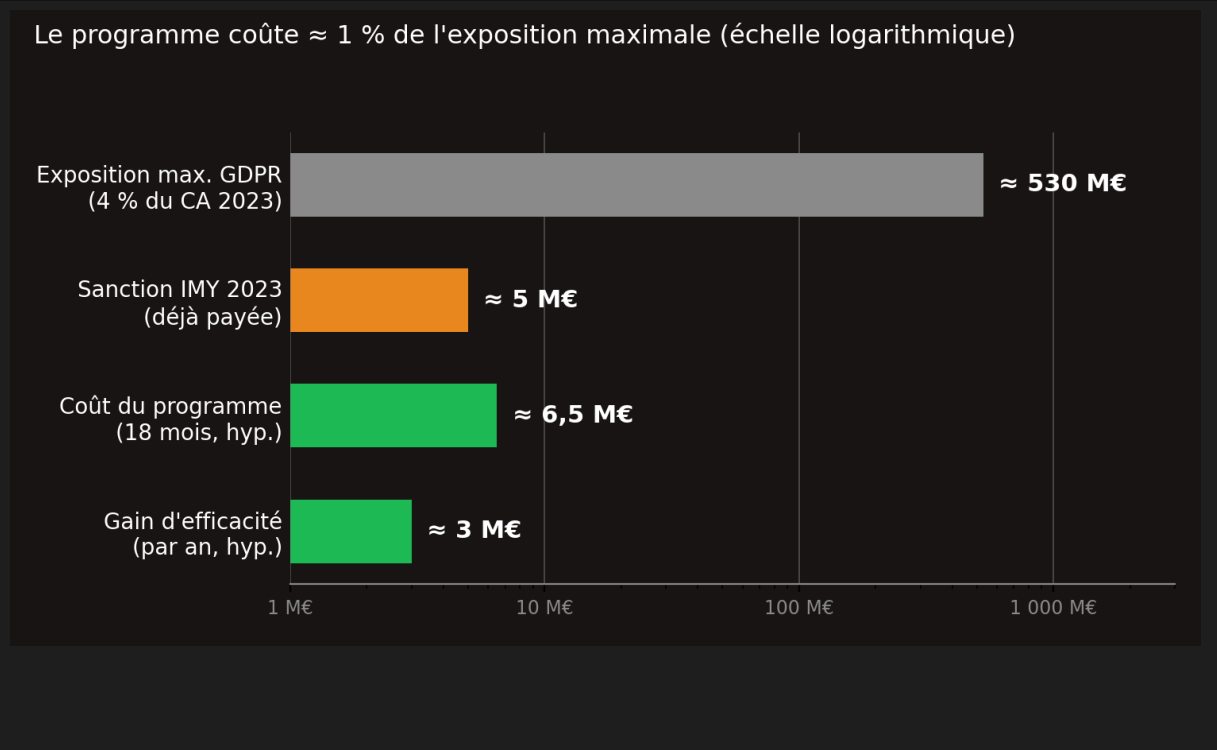
KPI (Pilot Template)	Cible M6	Source
Data Quality Score	-10 % de données manquantes (complétude > 98 %)	Great Expectations
Compliance Score	100 % des traitements avec base légale et consentement valide	OneTrust
Data Access Speed	-20 % de délai d'accès aux données	Catalogue
Risk Mitigation Score	100 % des datasets classifiés et chiffrés · 0 incident	Catalogue, Splunk
Droits des personnes	Effacement < 30 j, 100 % dans les délais légaux	Privacy Team

Livrables : Data Quality Report · Compliance Assessment · Technical Integration Plan · Risk Assessment Report · Stakeholder Feedback

Risques : résistance au changement (ateliers dès M1), intégration technique (POC en phase 1), dérive de périmètre (UE borné)

Impact business

≈ 6-7 M€ pour couvrir 530 M€ d'exposition — ordres de grandeur, hypothèses à affiner en phase 1



Compliance
Réduction du risque d'amende (jusqu'à 4 % du CA) ; pas de récidive IMY

Cost savings
-20 % de temps d'accès aux données ≈ 25 ETP libérés (hyp. 500 analystes × 2 h/sem.)

Trust
Transparence et contrôle → rétention UE ; différenciation vs Apple, Amazon, YouTube

Scalability
Absorbe la croissance (450 M → 600 M+) et les nouvelles réglementations

Coût 18 mois : personnel ≈ 1,9 M€ · licences ≈ 3 M€ · intégration 0,5-1 M€ · formation 0,3 M€. Phases 1-2 seules ≈ 2,5 M€. Le programme coûte ≈ 1 % de l'exposition maximale et à peine plus que l'amende déjà payée.

3 décisions à prendre aujourd'hui

Je ne demande pas 18 mois — je demande un CDO, 6 mois de budget et un message au personnel

1

Nommer le CDO

Prérequis bloquant de tout le plan : sans CDO, ni CoE ni stewards.

Action : profil validé et nomination sous 30 jours.

2

Approuver le budget phases 1-2

≈ 2,5 M€ sur 6 mois : CoE + Privacy Team, OneTrust, catalogue pilote, formation.

Action : décision budgétaire ce trimestre.

3

Lancer la communication interne

La résistance au changement est le risque n°1 identifié.

Action : message CEO + webinar CDO en M1.

Le pilote fera la preuve. Résultats présentés au Committee en M6 — Go/No-Go avant toute généralisation.

Annexes

Q&A anticipé (Executive Q&A Guide) · questions difficiles · références

Annexe — Q&A anticipé (1/3)

Executive Q&A Guide — 12 questions officielles

Q1 — Pourquoi maintenant ?

450 M d'utilisateurs, 180 pays, GDPR/CCPA/DSA, sanction IMY 2023, silos qui freinent l'innovation. Attendre, c'est laisser le risque croître avec l'échelle.

Q2 — Impact sur les opérations existantes ?

Le framework s'appuie sur l'existant (GCP, Airflow, Lexikon) : standards, owners et mesures, pas une nouvelle plateforme. Court terme : temps des stewards et formation ; long terme : moins de doublons, conformité fluide.

Q3 — Valeur business ?

Compliance (risque jusqu'à 530 M€), cost savings (accès aux données, moins de retraitements), trust (rétention), scalability. Coût ≈ 6-7 M€ sur 18 mois.

Q4 — Comment garantir la conformité GDPR/CCPA ?

Base légale documentée par finalité, consentement granulaire, 7 droits avec SLA, Privacy Team, DPO indépendant, DPIA, registre art. 30, checklist tenue à jour.

Annexe — Q&A anticipé (2/3)

Executive Q&A Guide — 12 questions officielles

Q5 — Pourquoi le CoE ?

Centralisé = goulot pour 180 pays ; embedded = les silos actuels. Le CoE combine standards communs et relais métier — modèle du guide et du cours pour une entreprise de cette taille.

Q6 — Comment mesurer le succès ?

KPIs avec baselines : complétude > 98 %, 100 % des demandes dans les délais, -20 % de délai d'accès, 0 incident critique, catalogue 100 %, > 90 % formés, maturité 3,4 → 4,2.

Q7 — Combien de temps ?

Pilote 4 mois (M3-M6), déploiement 12 mois, mode opérationnel à M18. Conforme au guide : pilote 3-6 mois, rollout 12-18 mois.

Q8 — Quels coûts ?

Personnel ≈ 1,9 M€, licences ≈ 3 M€, intégration 0,5-1 M€, formation 0,3 M€ → ≈ 6-7 M€ / 18 mois. Phases 1-2 ≈ 2,5 M€. Ordres de grandeur à affiner en phase 1.

Annexe — Q&A anticipé (3/3)

Executive Q&A Guide — 12 questions officielles

Q9 — Adaptation aux évolutions réglementaires ?

Veille DPO + Legal, revue annuelle de la politique, checklist trimestrielle, outils multi-juridictions ; DSA et AI Act déjà intégrés.

Q10 — Sécurité des données sensibles ?

Classification 4 niveaux, chiffrement, accès nominatif minimal et journalisé, SIEM, PCI-DSS via prestataire certifié + SAQ-A, protocole d'incident 72 h testé chaque année.

Q11 — Risques principaux ?

Résistance au changement (ateliers, stewards issus des équipes, quick wins) ; délais (phases bornées, Go/No-Go) ; coûts (budget par phase, licences négociées après audit de l'existant).

Q12 — Impact sur l'agilité ?

Positif : données trouvables et fiables = décisions plus rapides ; privacy by design dès les sprints = moins d'audits correctifs.

Annexe — questions difficiles

Hors guide — préparées pour la soutenance

Spotify a déjà un DPO et une plateforme data de pointe : pourquoi Governance 2/5 ?

Le niveau 2 mesure la gouvernance transverse, pas la technologie : pas de CDO, pas d'ownership par domaine, définitions divergentes, sanction 2023 sur la clarté de l'information. L'architecture est à 5 : c'est le paradoxe.

Pourquoi pas un data mesh, vu la culture squads ?

Compatible : les stewards par domaine sont les domain owners du mesh, le CoE fournit plateforme et standards fédérés. Le CoE est le nom du cours pour la couche de gouvernance fédérée.

5 stewards pour 180 pays, suffisant ?

5 stewards par domaine de données, pas par pays. Les spécificités locales (PDPA, LGPD) sont portées par le DPO et Legal ; relais régionaux en phase 3.

Base légale de la recommandation : consentement ou intérêt légitime ?

Contrat ou intérêt légitime pour la personnalisation du service, avec option non profilée (DSA art. 27) ; consentement pour la publicité ciblée et le partage à des tiers.

Que faites-vous des données inférées sensibles ?

Interdiction de profiler sur des catégories art. 9 inférées (humeur, religion, orientation), classe « Sensible » avec DPIA, audit des biais trimestriel.

Et si le pilote échoue ?

≈ 2,5 M€ engagés. Même en No-Go, on garde un catalogue User Data, une baseline qualité, un pipeline de droits testé et une équipe formée : le plan est ajusté, pas perdu.

Annexe — références

Sources publiques utilisées (vérifiées en septembre 2026)

- IMY (autorité suédoise), juin 2023 : amende administrative de 58 M SEK contre Spotify AB pour manquement au droit d'accès (art. 15 GDPR) ; confirmée par la cour administrative d'appel — imy.se / noyb.eu
- Spotify, rapport annuel 2023 (Form 20-F) : chiffre d'affaires 13,247 Md€ → 4 % ≈ 530 M€
- Spotify Engineering, février 2020 : « How We Improved Data Discovery for Data Scientists at Spotify » — catalogue interne Lexikon, migration GCP/BigQuery depuis 2016
- Business case Jedha : 450 M d'utilisateurs actifs, 200 M d'abonnés premium, 180+ pays (2023)
- Ressources Jedha : Governance Principles Guide, Data Maturity Assessment Template, Roles Template, Organizational Models Overview, Tech Tools Overview, Pilot Implementation Template, Executive Q&A Guide, Compliance Checklist
- Hypothèses (à valider en phase 1) : DPO en place, prestataire de paiement certifié PCI-DSS, part de métadonnées incomplètes, coûts du programme, gains d'efficacité